

10 questions before any AI tool touches company data.

Answer these before the pilot, not after the incident. "We haven't looked" is itself an answer — and the most common one.

01 Which company data must never reach an AI tool — and is that written down?

A one-page list, communicated to everyone, beats an unwritten understanding every time.

02 Where does this tool actually process our data?

Whose infrastructure, which region, under whose agreement — vendor marketing is not an answer.

03 Do the vendor's terms let it train on our data — and has anyone read them?

Accepted-on-signup is not reviewed. Check the training clause and the retention clause specifically.

04 Is there a defined purpose and lawful basis for any personal data the tool touches?

If personal data is involved, GDPR applies to the AI tool exactly as it does to any other processor.

05 Can personal data be stripped or pseudonymised before it reaches the model?

The strongest posture: sensitive fields removed by design before any model call — and tested, not assumed.

06 Would anyone know if personal data appeared in a prompt?

"No way to know" is the most common honest answer — and the clearest signal of unmanaged exposure.

07 Who can see the tool's outputs, logs and history — and how long are they kept?

Prompts and outputs are data too. They inherit every obligation the input data carried.

08 Is there a data-processing agreement, with sub-processors listed?

If the vendor can't produce a DPA and a sub-processor list, that tells you what you need to know.

09 Can we revoke the tool's access to our systems — quickly, and completely?

Access you can revoke any afternoon is a design decision. Access you can't is a dependency.

10 Do employees have written guidance on public AI chatbots — what may and may never go in?

People are already using them with company information. Guidance beats prohibition; silence beats neither.

Already done the check? Book the free 30-minute [AI Operating Map](#) session — where AI belongs in your company, where it must not go, and the first move worth funding: calendly.com/gergelyracz0/30min
Not yet? Take the free 3-minute check: www.leadflowautomation.net/check

Gergely Racz — PhD in Engineering (University of Cambridge) · 10+ years in AI · builds GDPR-gated AI systems for European companies · www.leadflowautomation.net

A practical checklist, not legal advice. © 2026 Lead Flow Automation.